

Plantilla de Reporte Ejecutivo en PowerPoint – GQM + PRAGMATIC + OCTAVE Nacional

Guion de diapositivas para presentar a la alta dirección el sistema de indicadores nacionales basado en OCTAVE, la metodología GQM y la evaluación PRAGMATIC.

Diapositiva 1 – Portada

- Título: Indicadores Nacionales de Ciberseguridad: OCTAVE, GQM y PRAGMATIC.
- Subtítulo: De los objetivos de país a los datos técnicos.
- Datos: institución, fecha, ponente.

Diapositiva 2 – Agenda

- Contexto normativo y estratégico (ENS, NIS2, Estrategia Nacional).
- Enfoque OCTAVE aplicado a nivel nacional.
- Metodología GQM + PRAGMATIC.
- Catálogo de indicadores clave.
- Resultados de ejemplo (IGM, métricas principales).
- Implicaciones para la toma de decisiones.
- Próximos pasos.

Diapositiva 3 – Contexto: por qué necesitamos mejores métricas

- Aumento de incidentes, sofisticación de amenazas, dependencia digital creciente.[web:87][web:19]
- Exigencias de ENS y NIS2 en gestión de riesgos, notificación de incidentes y gobernanza.[web:60][web:63][web:84][web:93]
- Necesidad de hablar de ciberseguridad en términos de riesgo, madurez y retorno de inversión, no solo de tecnología.

Diapositiva 4 – OCTAVE a escala nacional

- Resumen del enfoque OCTAVE (activos, amenazas, vulnerabilidades, riesgos, controles, resultados).
- Adaptación a nivel país:
- Activos: servicios esenciales, sistemas públicos, datos críticos.
- Amenazas: incidentes reportados, tendencias, vectores principales.
- Vulnerabilidades: sistemas vulnerables, exposición de servicios esenciales.
- Objetivo: construir una visión agregada del riesgo cibernético nacional.

Diapositiva 5 – Metodología GQM

- Breve definición: Goal–Question–Metric.[web:79][web:82][web:88]
- Cadena de trazabilidad:
- Objetivo: qué queremos mejorar/entender.
- Preguntas: qué necesitamos saber para saber si vamos bien.
- Métricas: qué datos concretos podemos medir.
- Mensaje clave: ningún indicador sin objetivo y preguntas explícitas.

Diapositiva 6 – Metodología PRAGMATIC

- Definición de los nueve criterios PRAGMATIC: Predictiva, Relevante, Accionable, Genuina, Significativa, Precisa, Oportuna, Independiente, Rentable.[web:83][web:86][web:89]
- Rol de PRAGMATIC: evaluar la calidad de cada métrica.
- Uso práctico: priorizar indicadores, refinar definiciones, descartar métricas poco útiles.

Diapositiva 7 – El catálogo de 15 indicadores OCTAVE nacionales

- Lista resumida de indicadores:
- Inventario de servicios esenciales digitalizados.
- Cobertura ENS.
- Protección de datos personales.
- Incidentes por sector y tendencia nacional.
- Amenazas contra disponibilidad.
- Sistemas vulnerables y exposición de servicios esenciales.
- Brechas de capacidad.
- Gobernanza y liderazgo.
- Capacidad de respuesta nacional.
- Cultura y formación.
- Pérdidas económicas estimadas.
- Continuidad de servicios esenciales.
- Confianza digital.
- Nota: cada indicador está definido mediante un objetivo GQM y evaluado con PRAGMATIC.

Diapositiva 8 – Ejemplo GQM: Inventario de servicios esenciales

- Objetivo: evaluar la identificación y gestión de activos TIC críticos en servicios esenciales.
- Preguntas clave:
- ¿Qué porcentaje de servicios esenciales tiene inventario TIC formal y actualizado?
- ¿En qué medida se integra con la gestión de riesgos y continuidad?
- Métrica principal: %SE_con_inventario.
- Resultado (ejemplo ficticio): 62 %.
- Implicación: 38 % de servicios esenciales carecen de base sólida para gestionar riesgos.

Diapositiva 9 – Ejemplo PRAGMATIC: Continuidad de servicios esenciales

- Métrica principal: nº de interrupciones significativas de servicios esenciales debidas a ciberincidentes, y horas de indisponibilidad.
- Evaluación PRAGMATIC (ejemplo):
- P: 5 (altamente predictiva del impacto social).
- R: 5 (relevancia directa para ciudadanía y política pública).
- A: 5 (altamente accionable: priorización de inversiones en resiliencia).
- Resto de criterios: mostrar resumen para ilustrar la lógica.
- Mensaje: métrica prioritaria en el cuadro de mando nacional.

Diapositiva 10 – Encaje con ENS y NIS2

- Diagrama que muestre cómo los 15 indicadores se alinean con:
- ENS (gestión de riesgos, medidas mínimas, vigilancia continua).
- NIS2 (gestión de riesgos, gobernanza, notificación de incidentes, continuidad).
- Mensaje: los indicadores ayudan a cumplir y demostrar cumplimiento, no son un ejercicio paralelo.
[web:60][web:63][web:84][web:93]

Diapositiva 11 – IGM y visión de madurez

- Explicar el Índice Global de Madurez (IGM) derivado de la encuesta OCTAVE nacional.
- Gráfico radar con dominios de madurez (Gobernanza, Activos, Riesgo, etc.).
- Mensajes clave:
- Dominios fuertes.
- Dominios débiles.
- Comparación con ejercicios anteriores o benchmarks, si existen.

Diapositiva 12 – ROI/ROSI de la ciberseguridad

- Metodología básica de cálculo de pérdidas esperadas y reducción de riesgo.[web:59][web:65]
[web:67][web:70]
- Resultado sintetizado (ejemplo ficticio):
- Reducción estimada de pérdidas anuales tras ciertas inversiones.
- ROSI > 0 como argumento de negocio.
- Mensaje: la ciberseguridad puede y debe hablar en el lenguaje del retorno de inversión, aunque con cautela metodológica.

Diapositiva 13 – Priorización basada en PRAGMATIC

- Mapa que cruce:
- Impacto en objetivos nacionales.
- Puntuación PRAGMATIC de las métricas.
- Identificación de indicadores "estrella" (altamente útiles) y "candidatos a revisión".
- Uso de la matriz para decidir qué se reporta a nivel político y qué se reserva para análisis técnicos.

Diapositiva 14 – Implicaciones para la toma de decisiones

- Decisiones estratégicas:
- Prioridad de sectores y servicios esenciales.
- Refuerzo de capacidades (CSIRTs, formación, gobernanza).
- Decisiones operativas:
- Focos de auditoría ENS/NIS2.
- Planes sectoriales específicos.
- Decisiones de inversión:
- Proyectos con mejor relación reducción de riesgo / coste.

Diapositiva 15 – Próximos pasos

- Consolidar la recogida de datos para cada indicador.
- Revisar periódicamente las puntuaciones PRAGMATIC y el catálogo de métricas.
- Integrar los indicadores en informes regulares al Consejo Nacional de Ciberseguridad y a otros órganos competentes.
- Planificar la siguiente iteración del IGM y del análisis de ROI/ROSI.

Diapositiva 16 – Mensaje final

- Resumen: OCTAVE aporta la lógica de riesgo, GQM la trazabilidad, PRAGMATIC la calidad, ENS/NIS2 la obligación, y el IGM/ROI el lenguaje de negocio.
- Cierre: "No podemos evitar todas las crisis, pero sí podemos decidir si llegamos a ellas con datos y criterio... o con fe y buena suerte".